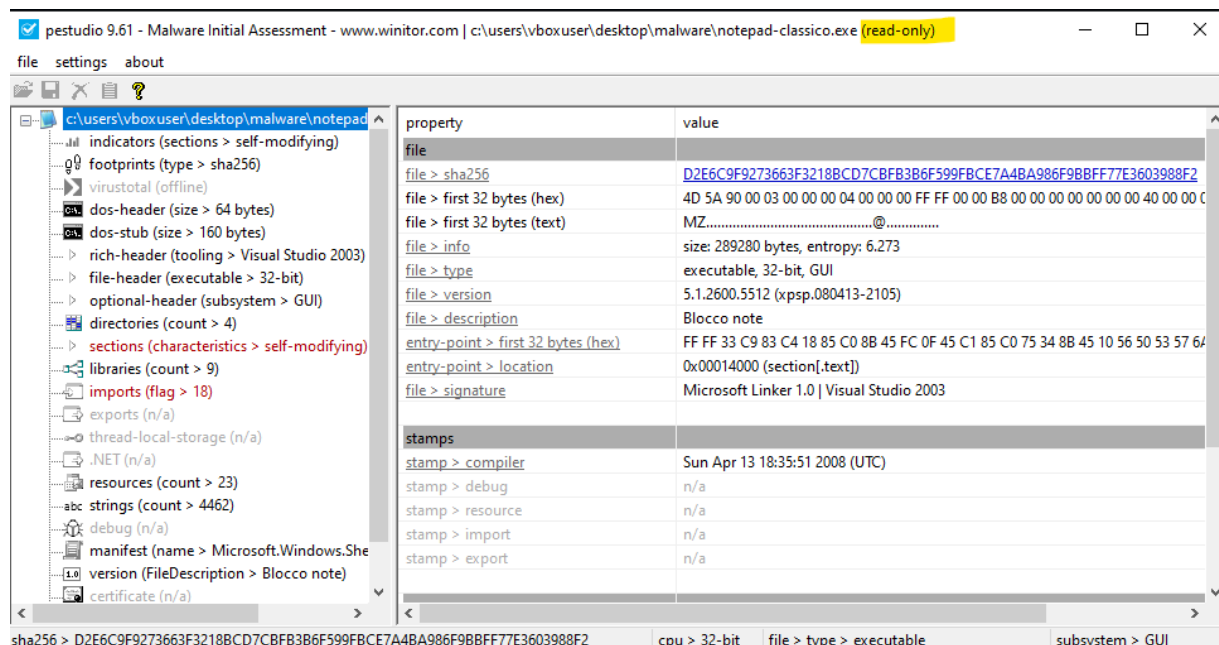


STATIC MALWARE ANALYSIS:

Analisi statica su pestudio del malware notepad-classico.exe su FlareVM.



Avvio pestudio, apro il file notepad-classico.exe in READ ONLY (analisi statica, non lo eseguo).

Posso notare già alcuni indicatori di attività sospetta.

<u>sections > self-modifying</u>	name: .text
<u>file > info</u>	size: 289280 bytes, entropy: 6.273
<u>imports > flag</u>	CloseClipboard DeleteFileW FindFirstFileW GetCurrentProcess GetC...
<u>manifest > general</u>	name: Microsoft.Windows.Shell.notepad, description: Windows Shell, se...

1) Sezioni con Self modifying & entropia abbastanza sospetta: Un entropia di 6.273 non è completamente sospetta ma è comunque qualcosa da tenere in considerazione, l'indicatore più preoccupante è il self modifying delle sezioni .text dove si trova il codice effettivo, sembra che l'exe in questo caso sia solo un wrapper per il codice malevolo che viene caricato in secondo tempo sulle sezioni .text, vedremo dopo in dettaglio.

2) Import di flag molto sospetti: Per un programma che si mostra come un semplice notepad chiede dei permessi estremamente riservati.

3) Manifest: il programma si manifesta come una windows shell legittima per evasione.

IMPORT FLAGS:

- 1) Clipboard flags: può chiudere e aprire clipboard, leggere se ci sono credenziali o informazioni di interesse molto probabilmente e rimpiazzare contenuti. Inoltre può controllare format per trovare dati sensibili specifici.
- 2) Operazioni File: Può trovare, cancellare, trovare attributi o scrivere su file, permettendo al malware di fare intrusione su file di sistema indebolendo le features di sicurezza o enumerando servizi, versioni, applicazioni, etc.
- 3) Map/Unmap: Mapping della memoria, può caricare file direttamente su memoria bypassando normale chiamata API e bypassando anche scan AV per injection su processi. Probabilmente spacchetta il payload dalla sezione .text e lo decripta direttamente in memoria per completo offuscamento.
- 4) Operazioni Registry: Crea nuove chiavi di registro per persistenza, può scrivere per modificarne gli attributi su quelle di sicurezza legittime, può aprire e chiudere keys per recon del registro.
- 5) WinEvents: Tramite SetWinEventHook installa un hook su tutto il sistema cominciando un monitoraggio di tutti gli input (keylogger/spyware)
- 6) GetDesktopWindow: enumerare le finestre aperte su vittima per trovare specifiche applicazioni
- 7) Winhelp: Help system di windows che può eseguire macro con payload secondari.

CloseClipboard	x
IsClipboardFormatAvailable	x
OpenClipboard	x
FindFirstFileW	x
GetFileAttributesW	-
IstrcmpW	-
MulDiv	-
IstrcpynW	-
LocalSize	-
GetLastError	-
WriteFile	x
DeleteFileW	x
GetACP	-
UnmapViewOfFile	x
MultiByteToWideChar	-
MapViewOfFile	x
RegCreateKeyW	x
IsTextUnicode	-
RegQueryValueExA	-
RegOpenKeyExA	-
RegSetValueExW	x
GetCurrentThreadId	x
UnhookWinEvent	x
DispatchMessageW	-
TranslateMessage	-
TranslateAcceleratorW	-
IsDialogMessageW	-
PostMessageW	-
GetMessageW	-
SetWinEventHook	x
GetDesktopWindow	x
GetFocus	-
LoadIconW	-
SetWindowTextW	-
PostQuitMessage	-
RegisterWindowMessageW	-
UpdateWindow	-
SetScrollPos	-
CharLowerW	-
EnableWindow	-
DrawTextExW	-
CreateDialogParamW	-
GetWindowTextW	-
GetSystemMetrics	-
MoveWindow	-
InvalidRect	-
WinHelpW	x

SEZIONI:

property	value	value	value	value	value	value
section	section[0]	section[1]	section[2]	section[3]	section[4]	section[5]
name	.text	.data	.rsrc	.text	.idata	.rsrc
section > sha256	181352B212CAF80C7A8FEAF...	87CBB581163F3AABE623127...	5E074AE0754BC823C26E8C3...	0033E40D79E7586AED87A86...	743DA029AE4A33E573F7043...	C913461089289C2D4410DAE...
entropy	6.214	1.149	5.421	6.428	5.439	5.407
file > ratio (99.65%)	10.62 %	0.71 %	12.57 %	61.59 %	1.59 %	12.57 %
raw-address (begin)	0x00000400	0x00007C00	0x00008400	0x00011200	0x0003CA00	0x0003DC00
raw-address (end)	0x00007C00	0x00008400	0x00011200	0x0003CA00	0x0003DC00	0x00046A00
raw-size (288256 bytes)	0x00007800 (30720 bytes)	0x00000800 (2048 bytes)	0x00008E00 (36352 bytes)	0x0002B800 (178176 bytes)	0x00001200 (4608 bytes)	0x00008E00 (36352 bytes)
virtual-address (begin)	0x00001000	0x00009000	0x0000B000	0x00014000	0x00040000	0x00042000
virtual-address (end)	0x00008748	0x0000ABA8	0x00013DB4	0x0003F6AC	0x0004113E	0x0004ADB0
virtual-size (292414 bytes)	0x00007748 (30536 bytes)	0x00001BA8 (7080 bytes)	0x00008DB4 (36276 bytes)	0x0002B6AC (177836 bytes)	0x0000113E (4414 bytes)	0x00008DB0 (36272 bytes)
characteristics	0x60000020	0xC0000040	0x40000040	0xE0000020	0xC2000040	0x40000040
write	-	x	-	x	x	-
execute	x	-	-	x	-	-
share	-	-	-	-	-	-
self-modifying	-	-	-	x	-	-
virtual	-	-	-	-	-	-

Noto che le sezioni .text sembrano avere un livello di entropia elevato, oltre che una discrepanza per quanto riguarda raw-size e virtual-size delle sezioni .data e in maniera meno marcata la sezione .idata.

Posso allora insinuare che il malware si modifica da solo per caricare sulle sezioni .text, in particolare la section[3] il payload come indicato anche da programma pestudio stesso cambia per inserire le linee di codice malware. Mentre per quanto riguarda la sezione .idata che normalmente è un import address table per le DLLs e funzioni è sospetto che essa permesso write. Su .data noto una grande differenza tra raw-size e virtual-size indicando un impacchettamento/compressione che in memoria si espande effettuando quindi azione indesiderate.

STRINGHE:

ascii	13	0x00007092	x	RegSetValueEx
ascii	12	0x000070C6	x	RegCreateKey
ascii	19	0x000071D8	x	GetCurrentProcessId
ascii	13	0x0000722A	x	FindFirstFile
ascii	9	0x00007290	x	WriteFile
ascii	10	0x00007310	x	DeleteFile
ascii	15	0x00007328	x	UnmapViewOfFile
ascii	13	0x00007350	x	MapViewOfFile
ascii	18	0x00007426	x	GetCurrentThreadId
ascii	17	0x0000746A	x	GetCurrentProcess
ascii	7	0x0000768A	x	WinHelp
ascii	14	0x00007722	x	CloseClipboard
ascii	26	0x00007734	x	IsClipboardFormatAvailable
ascii	13	0x00007752	x	OpenClipboard
ascii	14	0x00007830	x	UnhookWinEvent
ascii	15	0x000078B4	x	SetWinEventHook

ascii	15	0x000367FB	x	CreateNamedPipe
ascii	19	0x0003680F	x	GetCurrentProcessId
ascii	18	0x00036825	x	GetCurrentThreadId
ascii	15	0x0003688B	x	CreateNamedPipe
ascii	16	0x00036971	x	GetThreadDesktop
ascii	23	0x00036985	x	GetProcessWindowStation
ascii	24	0x0003699F	x	GetUserObjectInformation
ascii	23	0x000369C7	x	ImpersonateLoggedOnUser
ascii	16	0x000369E1	x	OpenProcessToken
ascii	21	0x000369F5	x	AdjustTokenPrivileges
ascii	20	0x00036A0D	x	LookupPrivilegeValue
ascii	19	0x00036A25	x	CryptAcquireContext
ascii	19	0x00036A3D	x	CryptReleaseContext
ascii	15	0x00036A53	x	CryptDestroyKey
ascii	16	0x00036A65	x	CryptSetKeyParam
ascii	14	0x00036A79	x	CryptGenRandom
ascii	14	0x00036A8B	x	CryptImportKey
ascii	12	0x00036A9D	x	CryptEncrypt
ascii	12	0x00036AAD	x	CryptDecrypt
ascii	17	0x00036ABD	x	CryptDuplicateKey
ascii	24	0x00036AD1	x	AllocateAndInitializeSid
ascii	25	0x00036B1D	x	SetSecurityDescriptorDacl
ascii	25	0x00036B39	x	SetSecurityDescriptorSacl
ascii	15	0x00036B55	x	SetEntriesInAcl
ascii	15	0x00036B69	x	OpenThreadToken
ascii	17	0x00036BEF	x	GetModuleHandleEx
ascii	14	0x00036C9B	x	RaiseException
ascii	21	0x00036D15	x	GetEnvironmentStrings
ascii	17	0x00036E15	x	OutputDebugString
ascii	18	0x000384AD	x	NtMapViewOfSection
ascii	15	0x000384E5	x	NtCreateSection
ascii	13	0x000384F5	x	NtOpenSection
ascii	18	0x00038515	x	NtMapViewOfSection
ascii	15	0x0003854D	x	NtCreateSection
ascii	13	0x0003855D	x	NtOpenSection
ascii	15	0x00039141	x	AddMandatoryAce
ascii	10	0x0003933D	x	OpenThread
ascii	12	0x00039355	x	NtOpenThread
ascii	25	0x0003999D	x	NtQueryInformationProcess
ascii	13	0x000399B9	x	NtQueryObject
ascii	12	0x0003D0BC	x	RegCreateKey
ascii	13	0x0003D100	x	RegSetValueEx
ascii	18	0x0003D11E	x	GetCurrentThreadId
ascii	17	0x0003D228	x	GetCurrentProcess
ascii	19	0x0003D350	x	GetCurrentProcessId
ascii	13	0x0003D3A2	x	FindFirstFile
ascii	9	0x0003D408	x	WriteFile
ascii	10	0x0003D488	x	DeleteFile
ascii	15	0x0003D4A0	x	UnmapViewOfFile
ascii	13	0x0003D4C8	x	MapViewOfFile
ascii	19	0x0003D712	x	GetForegroundWindow
ascii	16	0x0003D7E2	x	GetDesktopWindow
ascii	7	0x0003D904	x	WinHelp
ascii	14	0x0003D99C	x	CloseClipboard
ascii	26	0x0003D9AE	x	IsClipboardFormatAvailable
ascii	13	0x0003D9CC	x	OpenClipboard
ascii	14	0x0003DAAA	x	UnhookWinEvent
ascii	15	0x0003DB2E	x	SetWinEventHook

Posso vedere da string come il malware vada a modificare tokens, cerchi di infiltrarsi su processi in memoria, di creare meccanismi di persistenza su registry, di fare recon del sistema ed enumerare dati sensibili da cliboard o dalle finestre aperte, settare sistema di esfiltrazione dati con WinEventHook, modificare e cancellare file per ottenere miglior appoggio su vittima/privilege escalation/rimozione di safety features, oltre che criptare e decriptare i possibili payload offuscati quando necessario.

VIRUSTOTAL SCAN:

In quanto la mia flareVM era in rete interna e completamente isolata da internet/home network per un'analisi statica, pestudio non ha avuto accesso al risultato scan virustotal quindi ho inserito l'hash manualmente.

Risultato: 58/72 vendors hanno riputato il file malevolo, trojan (finge di essere notepad e si impersona come shell legittimo di windows) oltre che meterpreter (payload avanzato di framework metasploit, con configurazione e gestione dinamica)

The screenshot displays the VirusTotal interface for a file scan. At the top, a red circle indicates a Community Score of 58/72. The file's hash is d2e6c9f9273663f3218bcd7c6f3b6f59fbce7a4ba986f9bbff77e3603988f2, and it is identified as NOTEPAD.EXE. The file size is 282.50 KB, and it was last analyzed 5 months ago. The scan results show that 58/72 security vendors flagged the file as malicious. The file is categorized as a trojan, specifically trojan.rozena/meterpreter. The scan results show various security vendors' analysis, including AhnLab-V3, AliCloud, and Antiy-AVL. The file is also associated with several techniques, including Command and Scripting Interpreter, Obfuscated Files or Information, Query Registry, File and Directory Discovery, and Application Layer Protocol.

CONCLUSIONE:

Il binario è chiaramente offuscato/impacchettato, il payload è quasi certamente situato nelle sezioni .text in maniera cifrata/nascosta che viene decrittato una volta necessario, il malware sembrerebbe essere quindi uno spyware intento ad esfiltrare informazioni sensibili, credenziali e attività dell'utente vittima.

